



Кибербезопасность | Новости Кибербезопасности | Вредоносное ПО

Поддельные расширения Solidity Pro превращают инструменты для разработчиков в вредоносное ПО для кражи учетных данных



Автор Маюра Катир

10 августа 2026 года

Вредоносные расширения «Solidity Pro» злоупотребляют доверием, которое разработчики оказывают VS Code и инструментам Open VSX, превращаясь из

Компания Yeeth Security выявила двух издателей, `helper-beeps` и `web3devtoolsx`, распространяющих связанные `solidity-pro` пакеты, которые используют брендинг в стиле Solidity, обфускацию и частую смену версий, чтобы привлечь внимание разработчиков web3.

Эта кампания отражает методы, которые в публичных отчетах ассоциируются с предполагаемой «операцией Solidity Pro» от WhiteCobra, направленной на публикацию убедительных расширений, завышение показателей скачиваний, продвижение пакетов через социальные сети и быструю замену удаленных загрузок.

Ранние `solidity-pro` выпуски, от версии 1.0.0 до 2.4.x, представляли собой поэтапные дропперы. После установки расширение активировало компоненты с именами `Web3Analytics` и `ApiClient`, а затем ожидало в течение случайного интервала времени — от 12 часов до трех дней.

Этот временной барьер снижает вероятность автоматического анализа «песочницы», при котором расширение часто отслеживается лишь в течение короткого периода после установки.

При срабатывании расширения оно связывалось с инфраструктурой Cloudflare Worker, собранной из фрагментов строк в шестнадцатеричном формате.

Исследователи обнаружили домены, включающие `violet-87cardo[.]workers[.]dev`, `cardo[.]workers[.]dev`, и `soft-feather-7807.0x.cloudflare-workers[.]workers[.]dev`.

Расширение также генерировало ложный трафик, имитирующий запрос к API CoinGecko, что помогало вредоносным коммуникациям маскироваться под ожидаемую сетевую активность разработчиков или криптовалютную активность.

Автономное выполнение позволило полезной нагрузке сохраняться **за пределами хоста расширения VS Code**. В нескольких примерах также проверялись переменные `CI` и «песочницы», в том числе `CI`, `GITHUB_ACTIONS`, `JENKINS_HOME`, и `GITPOD_WORKSPACE_ID` — мера защиты от анализа, призванная предотвратить детонацию в контролируемых средах.

Сервер C2 вернул полезную нагрузку Python, зашифрованную с помощью алгоритма AES-GCM. Расширение создало ключ для расшифровки на основе встроенных материалов, записало восстановленный скрипт во временную папку или в домашний каталог и выполнило его через `Node.js child_process.spawn`.

Исследователи в области кибербезопасности из компании Yeeth заявили, что ранее в своем отчете `WhiteCobra Beginnings` они упоминали о предполагаемой операции, связанной с `WhiteCobra`, в ходе которой использовалось поддельное расширение `Hardhat Solidity`.

Начиная с версии 3.0.0, вредоносное ПО стало нацелено на прямое воровство. В более поздних версиях появились такие поля конфигурации, как `WORKERS` , `CID` , `MAX_FILES` и `MAX_VAULTS` , при этом для кражи использовалась **инфраструктура Telegram-бота**.

Новая функциональность была разработана с учетом важных данных, которые обычно хранятся на рабочих станциях разработчиков: токенов доступа к GitHub и GitLab, учетных данных AWS, токенов Cloudflare, ключей API OpenAI, токенов Telegram-ботов, закрытых ключей SSH, данных профиля браузера и артефактов, связанных с IPassword.

Криптовалюты были главной целью. Злоумышленник искал мнемонические фразы, расширенные приватные ключи Bitcoin WIF и данные хранилищ кошельков, связанные с MetaMask, Phantom, Rabby, Coinbase Wallet, Trust Wallet и Keplr.

Rather than relying on a generic clipboard monitor, the malware appears designed to locate files, profiles, secrets, and tokens accumulated during web3 development workflows.

Not every release contained obvious malicious code. `web3devtoolsx` published apparently clean versions, including 1.0.0 and 4.0.0, carrying benign-looking components such as `GasTracker` and `PriceMonitor` .

These decoy packages may serve to establish reputation, evade marketplace scrutiny, or test redeployment after a takedown.

The campaign demonstrates why extension names, polished READMEs, and download counts are weak trust signals.

Developers should validate publishers, review extension permissions and source code where possible, and avoid placing seed phrases or private keys into editor environments.

Organizations should maintain approved-extension allowlists, monitor registry changes, and revoke exposed tokens immediately if a suspicious Solidity-related



**Why use the 2026 Agentic SOC Buyer’s Guide? 8 Best Platforms
Compared – [Download the 2026 Buyer’s Guide](#)**